CRA Incident Simulation

Çıktı: Incident Workflow | EP 13 - Incident Response

Ad Soyad: **Grup:** **Tarih: 06.11.2026**

[V] Saat 10:15: servis hesabında yetkisiz erişim alarmı; PLC ayarları değişmiş olabilir, makine çalışıyor [F1]. [B] Gerçek servis hesabı/ağı bilinmiyor. Bu, olay tespiti değil, masa başı müdahale planıdır.

[D] Kaynakta doğrulanan | [B] Bilinmiyor | [V] Varsayım | [Ö] Öneri | [Ç] Analitik çıkarım

Görev - beş aşamalı zaman çizgisi [Ö]

1. 10:15-10:30 / ilk 15 dakika: kim aranır, ilk üç eylem?

Vardiya sorumlusu bakım/emniyet yetkilisini ve OT olay sorumlusunu bilgilendirir. (1) İnsanları tehlike alanından uzaklaştır; emniyet gösterilemiyorsa yetkili ekip kontrollü güvenli duruş ve yük tutmayı sağlar. (2) Şüpheli servis oturumunu güvenli biçimde sınırla. (3) Alarmı, saati ve ilk gözlemleri kaydet; rutin reset/yeniden başlatma yapma. Önce insan emniyeti [K5].

2. İlk 2 saat: emniyet, kanıt ve hangi hesap?

Bakım yetkilisi kapak/şerit duruşu, reset ve konfigürasyon bütünlüğünü onaylı referansla inceler; üretimde tehlikeli deneme yapmaz. OT sorumlusu şüpheli servis hesabını askıya alır, açık oturum ve varsa erişim anahtarlarını iptal eder. Mevcut erişim/PLC/HMI kayıtlarını ve ayar kopyalarını salt okunur saklar; hash, saat dilimi, kopyalayan kişi ve teslim zincirini kaydeder. Kanıt toplama emniyeti geciktirmez.

3. En geç 24 saat: erken uyarıda ne hazır olmalı?

Üreticinin yetkili olay/uyum ekibi kapsamı ve bildirim eşiğini değerlendirir. Kapsam ve eşik sağlanırsa gecikmeden, en geç farkındalıktan 24 saatte erken uyarı: ürün, farkındalık zamanı, kötü niyet şüphesi ve bilinen ilgili AB ülkeleri. Eksik ayrıntı kesinleşene kadar beklenmez. İşletme kanıtı üreticiye aktarır; öğrenci resmî bildirim yapmaz [K10, K11].

4. En geç 72 saat: etki, kök neden ve görev dağılımı?

OT ekibi erişim ve değişiklik izini; bakım/emniyet ekibi fiziksel etkiyi ve duruş durumunu araştırır. Üretici bildirim sorumlusu ilk etki değerlendirmesini, ürün bilgisini, alınan/önerilen önlemleri sunar. Kök neden henüz kanıtlanmadıysa açıkça belirsiz yazılır; 72 saatin dolması beklenmez. SRP üzerinden ilgili koordinatör CSIRT ve ENISA akışı izlenir [K10, K11].

5. 14. gün: rapor ve korunacak kayıtlar?

Föydeki 14. gün bu çalışmada ara değerlendirmedir; her olayın yasal son rapor tarihi değildir. Erişim/oturum izleri, varsa PLC/HMI kayıtları, önce-sonra ayarlar, hash'ler, olay çizelgesi, onaylar ve geri dönüş/validasyon sonuçları korunur. Rapor; doğrulanmış neden, fiziksel/üretim etkisi, önlemler ve açık işleri ayırır. Kayıtların var olduğu varsayılmaz; eksikliği yazılır.

CRA süreleri - olay türünü ayır [K10, K11]

Bildirim türü	Nihai rapor için üst süre
Aktif istismar edilen zafiyet	Düzeltici veya azaltıcı önlem kullanılabilir olduktan sonra en geç 14 gün.
Ürün güvenliğini etkileyen ciddi olay	72 saatlik olay bildiriminin sunulmasından sonra bir ay içinde.

Koşullu kapsam ve yeniden başlatma kararı

[B] AB piyasası/ürün kapsamı ve bildirim eşiği doğrulanmadı; her erişim alarmı otomatik CRA bildirimi değildir. 24/72 saat üreticinin ilgili olay/zafiyetten haberdar oluşundan sayılır; 10:15 alarmı ile aynı an olduğu varsayılmaz. Madde 14, 11.09.2026'dan uygulanır [K11]. [Ö] Bağımsız emniyet, onaylı ayarlar ve yetkiler doğrulanıp yetkili işletme ekibi yazılı onay vermeden yeniden başlatma yok.

EP 13: müdahale akışı ve kanıt listesi hazırdır; gerçek olay, resmî bildirim veya uygulanmış müdahale yoktur.

[F1] Dersin Lab Föyleri PDF dosyası, s. 7 (yerel) | [K5] NIST SP 800-82 Rev.3 | [K10] ENISA CRA SRP SSS | [K11] AB Komisyonu CRA bildirim | Bağlantılar tıklanabilir; kaynak/kanıt kaydı: docs/KAYNAKLAR.md. Erişim: 06.11.2026.